

NorthStream Technologies

Compliance Assessment Plan

Project Task 4 – Module 5: Developing Assessment Plan

Course: Cybersecurity Legislation and Compliance Assessments

Student: HASSANI Mohammad Salem

Date: January 25, 2026

Instructor: Asen Grozdanov

Module: 5 – Developing Assessment Plan

EXECUTIVE SUMMARY

This Compliance Assessment Plan defines the **scope, methodology, resources, and reporting approach** for a comprehensive 10–12 week cybersecurity compliance assessment of NorthStream Technologies Inc., a mid-sized Canadian software-as-a-service (SaaS) provider headquartered in Toronto, Ontario, with 250 employees[1].

NorthStream processes personal information of Canadian and international users, business data belonging to corporate clients across Canada, the United States, and the European Union, and employee records. The company offers cloud-based project management and collaboration tools with infrastructure hosted primarily on Amazon Web Services (AWS us-east-1 region) and secondary backup in AWS eu-west-1 for GDPR compliance[1].

This assessment plan aligns **NIST Cybersecurity Framework 2.0** assessment activities with applicable regulatory obligations identified in prior project phases, including:

- **Personal Information Protection and Electronic Documents Act (PIPEDA)** – Principle 4.7 (Safeguards)[1]
- **General Data Protection Regulation (GDPR)** – Articles 32 (Security of Processing) and 33 (Breach Notification)[1]
- **Quebec Law 25** – Articles 3–8 (Privacy Officer), Articles 13 (Explicit Consent), Articles 14–18 (Information Security Program)[1]
- **CIS Benchmarks** – Center for Internet Security baseline controls for Linux, Windows, and cloud infrastructure[2]

The plan uses a **five-phase structure** spanning 10–12 weeks, integrating framework-based assessment methodologies with technical scanning, administrative documentation review, stakeholder interviews, and third-party risk evaluation. Gap analysis will categorize compliance findings by severity (Critical, High, Medium, Low) and map gaps to specific regulatory requirements and NIST CSF 2.0 controls.

Estimated Assessment Cost: CAD \$75K–120K (internal resources + third-party tools/consulting)

Assessment Team: 4–5 full-time assessors + NorthStream liaison team

Expected Deliverable: Comprehensive assessment report with findings, recommendations, and remediation roadmap

SECTION 1: ASSESSMENT SCOPE DEFINITION

1.1 Systems and Assets In Scope

The compliance assessment will focus on **production and high-risk systems** directly supporting NorthStream's SaaS platform and handling personal information or confidential business data.

Production Web Application Tier: NorthStream's primary SaaS platform comprises 8–10 Linux web servers (Ubuntu 22.04 LTS) deployed across AWS us-east-1 Availability Zones, fronted by an Elastic Load Balancer (ELB) and protected by AWS Web Application Firewall (WAF). These servers host the project management and collaboration SaaS front-end application, serving approximately 2,000+ active corporate customers. Data classification: **Confidential – Customer Application Data and PII**. Approximate user base: 40,000+ active users across Canada, US, and EU. Backup strategy: Daily incremental snapshots to AWS S3 (us-east-1 + eu-west-1 for GDPR Article 32 compliance)[1].

Database and Storage Tier: NorthStream operates 4–6 managed database instances using Amazon Relational Database Service (RDS) with PostgreSQL 14.x engine, configured for Multi-AZ failover and automated backup retention (30-day snapshot window). Associated Amazon S3 buckets store structured customer data, authentication credentials, audit logs, and encrypted backups. Data classification: **Highly Confidential – Authentication Credentials, Sensitive PII, Payment Information**. Database engines: PostgreSQL 14.x (RDS) with encryption-at-rest enabled (AWS KMS CMK partially implemented). Access pattern: Direct access via VPC Endpoint; SSL/TLS enforced (TLS 1.2+). Backup encryption: Partial (some backups use AWS-managed keys, not customer-managed CMK per GDPR Article 32 requirement)[1].

Identity, Access, and Authentication Systems: NorthStream implements centralized identity and access management via Azure Active Directory (Entra ID) for employee SSO, multi-factor authentication (MFA), and role-based access control (RBAC) across cloud and on-premises resources. Third-party customer authentication uses OAuth 2.0 (Google, Microsoft, GitHub) and native username/password stored in PostgreSQL with bcrypt hashing. IdP provider: Azure AD (Entra ID) for employee/contractor accounts (~250 staff). MFA: Enabled for all administrative access; optional for standard users. External authentication: OAuth 2.0 (Google, Microsoft, GitHub) + native accounts. Data classification: **Confidential – Identity and Access Control Metadata**[1].

Cloud Infrastructure Components: NorthStream's AWS environment comprises 3 AWS accounts (Production, Staging, Development) with interconnected VPCs, security groups, Network ACLs, AWS Identity and Access Management (IAM) roles, AWS CloudTrail logging, Amazon CloudWatch monitoring, and AWS Systems Manager Session Manager for bastion-

less access. Network architecture: 3-tier VPC (public subnet with NAT Gateway, private subnet for web servers, database subnet with restricted egress). Data classification: **Internal – Configuration & Logging**, with some **Confidential** security event logs. Logging coverage: CloudTrail enabled for all API calls (90-day retention); CloudWatch Logs for application logs (14-day retention). Monitoring: Basic CloudWatch alarms for CPU, disk usage; no automated incident detection or SIEM integration[1].

Network Security Devices: NorthStream deploys virtual network security infrastructure protecting data flow between customer endpoints, AWS infrastructure, and employee networks. Includes AWS WAF (Web Application Firewall), AWS Security Groups (stateful firewall rules), VPC Flow Logs (enabled; sent to CloudWatch Logs for monitoring), and VPN Concentrator (Cisco AnyConnect VPN for remote employee access with 2FA via Okta). Data classification: **Internal – Network Telemetry & Security Events**[1].

Employee Endpoints and Critical Applications: A representative sample of 30–40 employee endpoints (Windows 11 Enterprise, macOS 13+) used by engineering, support, and finance teams. Windows 11 Enterprise: BitLocker disk encryption, Windows Defender Antimalware, Group Policy applied. macOS 13+: FileVault disk encryption, XProtect (Apple's built-in antimalware), Gatekeeper (code signing enforcement). Critical applications: Cisco AnyConnect VPN + Okta SSO (secure remote access), GitHub Enterprise (source code repository, API secrets in GitHub Secrets Manager), Jira (customer support tickets with PII), Microsoft 365 (email, OneDrive), DBeaver & pgAdmin (database access with direct SQL query execution). Data classification: **Internal to Confidential – Source Code, Support Logs, Limited PII**[1].

1.2 Compliance Requirements In Scope

The assessment will evaluate NorthStream's adherence to PIPEDA Principle 4.7 (Safeguards), requiring "appropriate physical, administrative and technological safeguards against unauthorized access, disclosure, modification or destruction" for employee records (1,200 staff) and Canadian customer data (1,800+ Canadian account holders). Focus: Access control (RBAC, least privilege), encryption (data at rest/transit), audit logging, incident response procedures[1].

GDPR Articles 32 (Security of Processing) and 33 (Breach Notification) apply to NorthStream's processing of EU customer personal data (150 customers in France, Germany, Netherlands). Article 32 requires "appropriate technical and organizational measures" including "pseudonymization and encryption of personal data" and "ability to ensure the ongoing confidentiality, integrity, availability and resilience of processing systems." Assessment will verify encryption at rest (AWS KMS CMK for EU data), encryption in transit (TLS 1.2+), backup encryption (GDPR Schrems II compliance with customer-managed keys), and backup restoration capabilities. Article 33 requires breach notification to supervisory authorities (CNIL, BfDI, AP) within 72 hours of breach awareness—assessment will verify incident response plan addresses this timeline explicitly[1].

Quebec Law 25 Articles 3–8 require appointment of a designated Privacy Officer and Articles 14–18 require an information security program proportionate to data sensitivity and processing risks. The program must include documented security policies (access control, encryption, incident response, data retention, vendor management), Privacy Impact Assessments before deploying new data processing systems, and breach notification to Commission d'Accès à l'Information (CAI) within 24 hours of awareness (faster than GDPR's 72 hours). Article 13 requires explicit, separate, informed consent for collection of sensitive data including precise geolocation, biometric data, and health information—NorthStream's

Rewards mobile app collects GPS location data and must implement separate, unchecked consent toggle with audit trail[1].

NIST CSF 2.0 Functions in scope: Govern (GV) – Risk management strategy, Privacy Officer appointment, organizational policies; Identify (ID) – Asset inventory, data classification, business environment understanding; Protect (PR) – Access control, encryption, security training; Detect (DE) – Incident detection, monitoring, incident categorization; Respond (RS) – Incident response procedures, breach notification timelines; Recover (RC) – Recovery planning, backup & restore procedures, resilience[1].

CIS Benchmarks for technical compliance validation: CIS Ubuntu Linux 22.04 LTS Benchmark v1.1.0 (for 8–10 Linux web servers), CIS Amazon Web Services Foundations Benchmark v2.0.0 (for AWS account, IAM, and infrastructure), CIS Microsoft Windows 11 Enterprise Benchmark v3.1.0 (for 30–40 Windows endpoints), CIS PostgreSQL 14 Benchmark v1.2.0 (for RDS PostgreSQL instances)[2].

1.3 Assessment Exclusions and Boundaries

Legacy Systems Scheduled for Decommissioning: NorthStream maintains a legacy Rewards Loyalty Database (Oracle 11g, End-of-Life January 2020) operated in Calgary data center, scheduled for complete decommissioning by March 31, 2026. This system handles historical customer rewards records (2015–2023) and is no longer processing active customer transactions. It is not assessed due to imminent decommissioning and no future business value[1].

Third-Party Cloud Services – SOC 2 Equivalence: Okta (Identity & Access Management), GitHub Enterprise (Source Code Repository), and Salesforce CRM will **NOT be directly audited** but will be evaluated through **SOC 2 Type II audit reports** provided by vendors. Assessment team will review SOC 2 Type II audit reports for control coverage, identify scope limitations & exceptions, document Complementary User Entity Controls (CUECs) that NorthStream must implement, and verify NorthStream has implemented all required CUECs[1].

Customer Data in Third-Party Integrations: NorthStream integrates with Slack, Microsoft Teams, and Zapier for workflow automation and collaboration. These services may transmit customer project metadata to third-party services. While integrated, these services are managed by the respective vendor's security controls (Slack SOC 2, Microsoft SOC 2) and governed by data processing agreements (DPA) with vendors. They are **NOT included in this assessment scope** (vendor controls assessed separately via SOC 2)[1].

Development/Testing Environments: NorthStream's Staging and Development AWS accounts are used for pre-production testing and engineer workstations with non-production data (test accounts, synthetic data). These environments are **NOT in scope** for this assessment (no production customer data) and will be assessed in future Phase 2 assessment (2027)[1].

Third-Party Backup and Disaster Recovery (Vendor Managed): NorthStream contracts with Veeam Backup & Replication and AWS Backup for automated backup and disaster recovery. Backup infrastructure is vendor-managed and governed by service-level agreements (SLAs) and SOC 2 audit reports. Assessment team will review SLA commitments (Recovery Time Objective – RTO, Recovery Point Objective – RPO), verify NorthStream's backup configuration settings (encryption, retention, geographical redundancy), and validate backup restore procedures via limited testing[1].

Geographical Scope – International Operations Beyond Primary Markets:

NorthStream has limited expansion into Australia (2 customers), Singapore (pilot project), and Japan (1 customer) with minimal customer base and no dedicated infrastructure. These markets are **NOT in assessment scope** (no compliance obligations under Australia Privacy Act, Singapore PDPA, or Japan APPI). Assessment covers primary markets: Canada (domestic HQ, employee records, 1,800+ Canadian customers) – PIPEDA & Quebec Law 25; EU (150 customers in France, Germany, Netherlands) – GDPR; US (450 customers) – State privacy laws assessed separately in future phase[1].

SECTION 2: ASSESSMENT TIMELINE AND PROJECT PLAN

2.1 Phase Structure – 10–12 Week Timeline

PHASE 1: PREPARATION AND PLANNING (Weeks 1-2)

Element	Details
Duration	January 27 – February 10, 2026
Key Activities	1. Kickoff meeting with CISO, Privacy Officer, IT leadership 2. Establish assessment governance (steering committee, communication plan) 3. Finalize assessment scope; confirm systems/regulations 4. Prepare detailed assessment procedures & tool list 5. Provision assessment tools (licenses, access credentials)
Responsible Parties	Lead Auditor, CISO, Privacy Officer, IT Operations Manager, Technical Liaison
Deliverables	✓ Kick-off meeting minutes ✓ Assessment procedures manual ✓ Tool deployment checklist ✓ Timeline confirmation ✓ Risk assessment (key person unavailability, system downtime)

PHASE 2: DOCUMENTATION REVIEW AND STAKEHOLDER INTERVIEWS (Weeks 3-4)

Element	Details
Duration	February 10 – February 24, 2026
Key Activities	1. Review existing policies (security, incident response, data classification, access control, privacy, training) 2. Conduct 8–10 stakeholder interviews (CISO, IT Ops Manager, Privacy Officer, HR Manager, Product Owner) 3. Map existing controls to NIST CSF functions

Responsible Parties	Lead Auditor, Compliance Analyst, CISO, IT Operations, Privacy Officer
Deliverables	✓ Policy & procedure gap list ✓ Interview notes & findings summary ✓ Current-state NIST CSF maturity assessment ✓ Risk register (gaps by severity) ✓ Control mapping matrix

PHASE 3: TECHNICAL ASSESSMENT AND SCANNING (Weeks 5-7)

Element	Details
Duration	February 24 – March 17, 2026
Key Activities	1. Configuration Compliance Scanning (OpenSCAP for Linux; Nessus for Windows; AWS Config for cloud) 2. AWS Infrastructure Audit (CloudTrail, S3 encryption, IAM roles, security groups) 3. Database Hardening Assessment (PostgreSQL configuration, TLS, encryption, user access) 4. Endpoint Security Assessment (sample Windows 11 & macOS security posture) 5. Encryption Validation (at rest, in transit, key management) 6. Network Security Assessment (WAF rules, VPN, DDoS mitigation)
Responsible Parties	Technical Assessors (2), IT Operations, Technical Liaison
Deliverables	✓ CIS Benchmark scan results ✓ Encryption audit report ✓ Database hardening assessment ✓ Network security assessment ✓ Endpoint security compliance report ✓ Gap log (categorized by CIS control, severity)

PHASE 4: FINDINGS ANALYSIS AND VALIDATION (Weeks 8-9)

Element	Details
Duration	March 17 – March 31, 2026

Key Activities	1. Gap Analysis & Categorization (map findings to NIST CSF; categorize by severity) 2. Root Cause Analysis (why do gaps exist?) 3. Control Validation Testing (proof-of-concept tests on sampled controls) 4. Risk Rating (likelihood × impact analysis) 5. Draft Findings Presentation (preliminary findings summary) 6. Third-Party SOC 2 Review (verify Okta, GitHub, Salesforce SOC 2 coverage & CUECs)
Responsible Parties	Lead Auditor, Compliance Analyst, CISO, Privacy Officer
Deliverables	✓ Comprehensive findings log ✓ NIST CSF maturity assessment (updated) ✓ SOC 2 CUEC verification report ✓ Draft findings presentation ✓ Risk register (final, prioritized)

PHASE 5: REPORT DEVELOPMENT AND PRESENTATION (Weeks 10–12)

Element	Details
Duration	March 31 – April 21, 2026
Key Activities	1. Final Report Writing (Executive Summary, Methodology, Findings, Recommendations) 2. Remediation Roadmap (90–180 day remediation plans for Critical & High findings) 3. Executive Presentation (findings presentation to Board/leadership) 4. Follow-Up Assessment Planning (Phase 2 scope, timeline, resources)
Responsible Parties	Lead Auditor, Compliance Analyst, Assessment Team, CISO
Deliverables	✓ Final Compliance Assessment Report (PDF, 10–15 pages + appendices) ✓ Remediation roadmap ✓ Executive presentation deck ✓ Assessment metrics summary ✓ Phase 2 planning document

2.2 Key Milestones

#	Milestone	Target Date	Success Criteria
M1	Kick-off Complete & Scope Finalized	Feb 10, 2026	All stakeholders at kick-off; scope signed off; procedures manual finalized; tools provisioned & tested
M2	Documentation Review & Interviews Complete	Feb 24, 2026	8–10 interviews conducted; policies/procedures reviewed; maturity assessment (baseline) completed; risk register documented
M3	CIS Benchmark Scanning & Technical Assessment Complete	Mar 17, 2026	Scans completed (Linux, Windows, AWS, database); results documented; encryption validation complete; network assessment finalized
M4	Findings Analysis & Risk Rating Finalized	Mar 31, 2026	Gaps categorized by severity; root cause analysis documented; SOC 2 CUEC verification complete; draft findings validated with CISO
M5	Final Report & Remediation Roadmap Approved	Apr 14, 2026	Report written & reviewed; remediation roadmap developed (owners & timelines); presentation prepared; CISO approval obtained
M6	Executive Presentation & Stakeholder Alignment Achieved	Apr 21, 2026	Presentation delivered to Board/leadership; Q&A completed; roadmap accepted; Phase 2 planning initiated

SECTION 3: ASSESSMENT METHODOLOGY

3.1 Framework-Based Approach

NorthStream's compliance assessment is grounded in the **NIST Cybersecurity Framework 2.0 (NIST CSF)**, selected in Project Task 3 as the primary governance structure for Phase 1 (2026–2027). NIST CSF provides a structured, control-oriented approach to evaluate organizational capabilities across six Functions[3].

Assessment Approach by NIST CSF Function:

Govern (GV): The Govern function establishes organizational leadership, risk management strategy, policies, and oversight structures. Assessment will focus on: GV.OC-01 (Does NorthStream understand its mission, stakeholder expectations, and regulatory obligations?), GV.RK-01 (Is risk management integrated into organizational strategy?), and GV.OV-01 (Are

security policies documented, approved, and communicated?). Assessment methods include leadership interviews (CISO, CFO, General Counsel), policy review, risk register review, and Board committee minutes. Success criteria: Documented organizational risk management strategy; Privacy Officer appointed; Board-level cybersecurity oversight.

Identify (ID): The Identify function focuses on understanding organizational assets (data, systems, people), business environment (mission, critical functions, dependencies), and risks. Assessment will evaluate: ID.AM-01 (Does NorthStream maintain a current inventory of organizational assets?), ID.BE-01 (Is organizational mission documented with critical functions identified?), and ID.RA-01 (Are risks to organizational assets identified and prioritized?). Assessment methods include data asset inventory review, strategic documents review, and risk assessment process validation. Success criteria: Documented inventory of systems and data types with classification applied; documented mission and critical business functions; asset-based risk register.

Protect (PR): The Protect function implements controls to mitigate risks: access control, encryption, training, and secure configuration. Assessment will focus on: PR.AC-01 & PR.AC-02 (Are physical and logical access managed with least privilege, MFA, and audit logging?), PR.DS-01 & PR.DS-02 (Is sensitive data encrypted at rest and in transit?), and PR.AT-01 (Are staff trained on security policies, incident response, and data handling?). Assessment methods include access control policy review, IAM role audit, database user access audit, encryption configuration audit, and training program review. Success criteria: RBAC implemented with least privilege; MFA enabled for all administrative access; encryption enabled for sensitive data; staff training completed annually[3].

Detect (DE): The Detect function establishes capabilities to identify cybersecurity incidents when they occur. Assessment will evaluate: DE.CM-01 (Are security events monitored and analyzed for anomalies?) and DE.DP-01 (Are security incidents detected and categorized?). Assessment methods include SIEM/monitoring tool assessment, log aggregation review, alert configuration audit, and incident response simulation. Success criteria: Centralized log collection (CloudWatch, Splunk); real-time alerts for suspicious activity; documented incident detection procedures; breach assessment process[3].

Respond (RS): The Respond function defines incident response procedures, containment strategies, and regulatory notification. Assessment will focus on: RS.RP-01 (Are incident response procedures documented & practiced?), RS.RP-02 (Are containment procedures effective?), and RS.CO-01 & RS.CO-02 (Are customers, regulators, and media notified appropriately?). Assessment methods include incident response plan review, response team interviews, tabletop exercise, and communication templates review. Success criteria: Documented incident response procedures with defined roles; containment procedures documented; customer notification and DPA notification (GDPR Article 33 – 72 hours; Law 25 – 24 hours) procedures documented[3].

Recover (RC): The Recover function restores normal business operations post-incident, with focus on backup, disaster recovery, and resilience. Assessment will evaluate: RC.RP-01 & RC.IM-01 (Are backup and recovery procedures documented and tested?) and RC.IM-02 (Are systems resilient to service disruptions?). Assessment methods include backup strategy review, RTO/RPO validation, recovery test results review, and system architecture review. Success criteria: Backup policy documented (frequency, retention, encryption); RTO/RPO defined for critical systems; recovery tested annually; critical systems have redundancy[3].

3.2 Technical Assessment Methods

Configuration Compliance Scanning: Automated vulnerability scanning and configuration hardening assessment using industry-standard tools to validate systems against CIS Benchmarks and NIST controls. **Tool Selection:** OpenSCAP (primary – free, NIST-endorsed, 90%+ CIS coverage for Linux), Lynis (supplementary – quick baseline validation, free), Nessus Policy Compliance (supplementary – Windows endpoint scanning, CAD \$3K–5K annually). Optional: CIS-CAT Pro Assessor (highest accuracy 98%, CAD \$8K–15K annually)[2].

Scope of Configuration Compliance Scanning:

- **Linux Web Servers (8–10 systems):** Target CIS Benchmark CIS Ubuntu Linux 22.04 LTS Benchmark v1.1.0. Focus areas: access control (sudo configuration, file permissions, password policies), filesystem configuration (secure mount options), network hardening (firewall rules, SSH hardening), logging & monitoring (rsyslog configuration, audit logging), malware protection (ClamAV antimalware presence). Assessment activity: Deploy OpenSCAP scan against each web server (Week 6 baseline, Week 7 validation). Expected outcome: CIS Ubuntu compliance percentage (target >85%)[2].
- **Windows Endpoints (sample of 10 systems):** Target CIS Benchmark CIS Microsoft Windows 11 Enterprise Benchmark v3.1.0. Focus areas: firewall & network protection (Windows Defender Firewall, network policies), user access control (UAC enforcement, privilege escalation prevention), account policies (password complexity, lockout, history), disk encryption (BitLocker status, TPM settings), antimalware (Windows Defender or third-party). Assessment activity: Deploy Nessus Policy Compliance agent to sample endpoints. Expected outcome: Windows 11 compliance percentage[2].
- **AWS Infrastructure:** Target CIS Benchmark CIS Amazon Web Services Foundations Benchmark v2.0.0. Focus areas: IAM (users/roles, MFA, key rotation), logging & monitoring (CloudTrail, CloudWatch, VPC Flow Logs), networking (security groups, NACLs, VPN), storage (S3 bucket encryption, public access blocks), data protection (encryption at rest/transit). Assessment activity: AWS Config automated compliance checks (CIS mapping); manual API audit; document non-compliant resources. Expected outcome: AWS CIS compliance percentage; gap list for remediation[2].
- **PostgreSQL Database:** Target CIS Benchmark CIS PostgreSQL 14 Benchmark v1.2.0. Focus areas: authentication (password policies, user privileges, authentication method), user access control (role-based access, segregation of duties), logging (query logging, connection logging, audit trail), encryption (SSL/TLS for client connections, data at rest), database hardening (extensions, configuration settings). Assessment activity: Connect as DBA; execute CIS Benchmark SQL queries; test encryption; audit system privileges. Expected outcome: PostgreSQL CIS compliance; gap list[2].

3.3 Administrative Assessment Methods

Documentation Review: Systematic review of organizational policies, procedures, and supporting documentation to validate administrative controls. **Documentation types to review (5–7 minimum):**

1. **Information Security Policy:** Defines information security objectives, roles (CISO, Privacy Officer), access control principles, encryption requirements, incident response procedures. Assessment question: Does policy explicitly reference GDPR Article 32 encryption requirements, PIPEDA Principle 4.7 safeguards, Law 25 Article 14 documentation requirements? Success criteria: Policy exists, board-approved, version-controlled, communicated to all staff[1].
2. **Incident Response Procedure & Plan:** Defines incident detection, assessment, containment, recovery, notification procedures. **CRITICAL for this assessment** – must include: Detection procedures, incident categorization, breach assessment timeline, **GDPR Article 33 compliance** (72-hour notification to DPA – CNIL, BfDI, AP for EU data breaches), **Law 25 compliance** (24-hour notification to CAI for Quebec data breaches), **PIPEDA compliance** (risk-based notification). Assessment question: Does plan explicitly document 72-hour GDPR timeline with DPA contact info? Success criteria: Plan exists, reviewed annually, tabletop exercise conducted, staff trained[1].
3. **Data Classification & Privacy Policy:** Defines data categories (public, internal, confidential, restricted) and privacy rights. Must address data types collected (customer PII, employee data, business data), legal basis for collection (consent, contract, legal obligation, legitimate interest), **Quebec Law 25 Article 13 compliance** (for sensitive data – geolocation, biometric, health – explicit mention of separate express consent requirement), data retention periods, and data subject rights (access, correction, deletion under GDPR/PIPEDA/Law 25). Assessment question: Does privacy policy mention "separate express consent" for location data per Law 25 Article 13? Success criteria: Policy addresses all data types; legally compliant language; publicly available[1].
4. **Access Control & Segregation of Duties Policy:** Defines who has access to what systems/data, based on job role. Must include: Principle of least privilege (users granted minimum access necessary), segregation of duties (payroll clerk cannot approve payroll; separate roles), approval workflow (who approves access requests?), quarterly access reviews (managers verify staff still need assigned access), termination procedures (access revoked when employee leaves). Assessment question: For HR system containing employee SINs, is access limited to payroll role only (not benefits analyst, not HR admin)? Success criteria: Policy documented; IAM tool enforces policy; quarterly reviews conducted with evidence[1].
5. **Encryption & Key Management Policy:** Defines encryption standards and key management procedures. Must address: Data at rest (which data must be encrypted? All sensitive/confidential data), encryption standard (AES-256 for symmetric, RSA-2048+ for asymmetric), key generation (how keys are created, stored, protected), key rotation (frequency – annual minimum per GDPR/PIPEDA), key escrow (backup key storage for disaster recovery), **GDPR Schrems II compliance** (AWS KMS Customer Master Keys for EU data, not AWS-managed keys). Assessment question: Does policy explicitly require AWS KMS CMK for EU backup data to address Schrems II? Success criteria: Policy documented; encryption enabled on all systems; key rotation logs available[1].
6. **Vendor Risk Management & Third-Party Assessment:** Defines how NorthStream evaluates third-party vendors (Okta, GitHub, Salesforce, AWS). Must include: Vendor selection criteria (security certifications: SOC 2, ISO 27001), Data Processing Agreement (DPA) with all vendors handling personal data, risk assessment (annual review of vendor controls via SOC 2 reports), incident notification

(vendor must notify NorthStream of breaches within 24 hours), termination (vendor must delete/return data upon contract end). Assessment question: Are SOC 2 Type II audit reports available for Okta, GitHub, Salesforce? Have DPAs been executed? Success criteria: Vendor risk policy documented; SOC 2 reports obtained; DPAs signed; annual review conducted[1].

7. **Employee Security Training & Awareness Policy:** Defines mandatory security training for all staff. Must cover: Annual mandatory training (minimum 1 hour, covers GDPR/PIPEDA/Law 25 basics), role-specific training (e.g., CISO/Privacy Officer: 40+ hours on compliance frameworks), incident reporting procedures (how to report suspected breach), phishing awareness (identifying suspicious emails), data handling (classification, encryption, retention), GDPR/PIPEDA/Law 25 obligations (72-hour, 24-hour, risk-based notification). Assessment question: Have all 250 NorthStream staff completed annual security training? Success criteria: Training completed by >95% of staff; attendance records maintained; content updated annually[1].

Stakeholder Interviews (4–5 key roles with 8–10 minimum questions):

CISO Interview Questions:

1. "What is NorthStream's target maturity level for the NIST CSF Govern function by end of 2026?"
2. "Walk me through your last incident response scenario. How would you detect, assess, and notify regulators?"
3. "Are you aware of the GDPR Article 33 72-hour DPA notification requirement? How does your incident response plan address this?"
4. "Is a Privacy Officer appointed? If external, what's the engagement model?"
5. "What is your top GDPR/PIPEDA/Law 25 compliance risk at NorthStream?"

IT Operations Manager Interview Questions:

1. "Are the S3 backups encrypted with AWS KMS Customer Master Keys or AWS-managed keys?"
2. "How often are security patches applied to the 8 web servers? Do you have a patch management policy?"
3. "Are the 10 Linux web servers compliant with the CIS Ubuntu Linux 22.04 LTS Benchmark? How do you validate compliance?"
4. "If an employee in the payroll department is terminated, what's the process to revoke access to the HR system?"
5. "Walk me through your backup procedure for the PostgreSQL database. Is the backup encrypted?"

Privacy Officer Interview Questions:

1. "Describe the Privacy Officer role at NorthStream. Is it full-time, part-time, or external?"
2. "Walk me through a scenario: you're notified of unauthorized access to the EU customer database at 2 AM. What's your process? When must you notify the CNIL (France), BfDI (Germany), AP (Netherlands)?"

3. "Are Privacy Impact Assessments conducted before deploying new systems? Do you have a PIA template?"
4. "Have Data Processing Agreements been executed with AWS, Okta, GitHub, and Salesforce?"
5. "What is NorthStream's data retention policy for customer data? How long do you keep employee records?"

3.4 Third-Party Risk Evaluation

Assessment of NorthStream's cloud service provider controls via SOC 2 Type II audit reports and Complementary User Entity Controls (CUECs) verification. Assessment team will: (1) Request SOC 2 Type II audit reports from Okta, GitHub, Salesforce, and AWS (current year); (2) Review audit scope to verify coverage of services used by NorthStream; (3) Identify scope limitations or exceptions; (4) Identify CUECs – controls that NorthStream must implement because vendors do not provide them (Example: AWS encrypts data at rest [covered by SOC 2], but NorthStream must select encryption keys [AWS KMS CMK for GDPR Schrems II compliance] ← NorthStream responsibility); (5) Verify NorthStream has implemented CUECs; (6) Document findings[1].

3.5 Gap Analysis Approach

Systematic identification, categorization, and mapping of compliance gaps discovered during assessment phases:

Gap Types:

1. **Control Gap:** Control does not exist at all (Example: "No Privacy Officer appointed" per Law 25 Articles 3–8; severity: Usually Critical or High)[1]
2. **Implementation Gap:** Control exists but is partially or incorrectly implemented (Example: "Incident Response Plan exists but does not address GDPR 72-hour DPA notification"; severity: Usually High or Medium)[1]
3. **Documentation Gap:** Control exists and works, but is not documented (Example: "Access control exists in practice [IT Ops enforces least privilege], but no written access control policy"; severity: Usually Medium or Low)[1]

Severity Levels:

- **CRITICAL:** Legal/regulatory non-compliance resulting in major fine (GDPR EUR €8–15M, Law 25 CAD \$100K–1M); could result in major data breach; violates core security principle. Examples: Privacy Officer not appointed; encryption not enabled for EU backups; GDPR breach notification procedures not documented[1]
- **HIGH:** Non-compliance with important regulatory requirement; could result in significant data loss or breach; partial implementation of critical control. Examples: Access control exists but lacks audit logging; Incident response plan exists but 72-hour DPA notification not mentioned; database has unauthorized users with elevated privileges[1]
- **MEDIUM:** Non-compliance with framework best practice (not strictly required by law); could result in operational issue or minor regulatory gap. Examples: CIS

Benchmark compliance at 75% (target 85%+); security training not completed by all staff[1]

- **LOW:** Documentation improvement or procedural refinement; minimal regulatory or business impact. Examples: Access control policy exists but needs updated formatting; Interview notes not documented[1]

Gap Mapping: Each gap is linked to applicable regulation (GDPR Article 32, PIPEDA Principle 4.7, Law 25 Article 14), NIST CSF control (GV.OC-01, PR.AC-01, PR.DS-01, RS.RP-01), and CIS Benchmark (Linux.1.1, Windows.18.8, AWS-Foundational.1.1). For each gap, assessment team will: (1) State current condition (evidence from scanning/interviews); (2) State required condition (per regulation/standard); (3) Identify root cause (why does gap exist?); (4) Recommend remediation (how to fix it?); (5) Estimate remediation effort (timeline & cost); (6) Assign remediation owner[1].

SECTION 4: RESOURCE REQUIREMENTS

4-5 Full-Time Assessors: Lead Auditor / Assessment Manager (1 FTE; CISM/CISSP certified; 10+ years experience; CAD \$150–200/hour × 400 hours = CAD \$60K–80K external cost), Technical Assessors / Security Engineers (2 FTE; Linux/Windows/AWS experience; CAD \$120–150/hour × 800 hours = CAD \$96K–120K external cost), Compliance / Privacy Analyst (1 FTE; privacy law knowledge; CIPP or equivalent; CAD \$100–130/hour × 400 hours = CAD \$40K–52K external cost), Optional External Privacy Consultant (50–100 hours as-needed; GDPR/PIPEDA expertise; CAD \$200–250/hour × 75 hours = CAD \$15K–18.75K)[1].

NorthStream Internal Resources (3-4 individuals, part-time): CISO (20–30 hours/week; steering committee, interviews, provide access, review findings, executive sign-off), IT Operations Manager (10–20 hours/week; grant system access, respond to technical questions, facilitate log access, support CIS scanning), Privacy Officer / DPO (10–20 hours/week; interview participation, provide policies/PIAs/DPAs, clarify procedures, support regulation interpretation), Technical Liaison (5–10 hours/week; facilitate system access, answer configuration questions, provide documentation, support remediation planning)[1].

Key Tools & Technology: OpenSCAP (FREE), Lynis (FREE community), Nessus Policy Compliance (CAD \$3K–5K annually), Optional CIS-CAT Pro Assessor (CAD \$8K–15K annually), AWS Config (CAD \$2–5/month per resource), CloudTrail logs (CAD \$0.20/month per 100K events), shared assessment workbook (Excel or Google Sheets), video conferencing (Zoom, Teams), file sharing (OneDrive, Google Drive). Infrastructure access required: VPN access to NorthStream AWS accounts, RDP/SSH access to sample systems, Okta SSO to internal systems, email access for interviews[1].

SECTION 5: REPORTING PLAN

Interim Reporting: Weekly progress updates to CISO + steering committee (1-page email every Monday) with completed/planned activities and blockers. Mid-assessment checkpoint at Week 6 (30-minute meeting + 5-page summary document) to validate findings and gather feedback from CISO & IT leadership[1].

Final Report Structure: Comprehensive Assessment Report (10–15 pages + appendices) including: (1) Executive Summary (1 page) – scope overview, key findings summary (critical vs. high vs. medium), overall compliance rating, high-level remediation recommendations; (2) Assessment Methodology & Scope (2 pages) – scope definition, regulations, framework, assessment tools, team composition; (3) Detailed Findings & Analysis (8–10 pages) – findings organized by NIST CSF Function with finding description, current condition (evidence), required condition (regulation/standard), risk severity, root cause, compliance mapping; (4) Compliance Maturity Assessment (1–2 pages) – NIST CSF maturity rating for each function (current state vs. target state); (5) Remediation Roadmap (2 pages) – for each CRITICAL & HIGH finding, provide remediation steps, timeline, cost estimate, responsible owner, acceptance criteria, target completion date[1].

Appendices (NOT counted in 10-page limit):

- **Appendix A: References** – NIST CSF, GDPR, PIPEDA, Quebec Law 25, CIS Benchmarks, AICPA SOC 2[1]
- **Appendix B: Sample Interview Questions** – minimum 10 questions across stakeholder groups[1]
- **Appendix C: Compliance Tracking Checklist** – 1-page matrix showing how controls are tracked (Control ID, Control Name, Current State, Target State, Gap Type, Severity, Owner)[1]
- **Appendix D: Risk Rating Criteria** – simple table defining Critical/High/Medium/Low severity[1]

Executive Presentation (Week 12): Deliver findings presentation to NorthStream Board/executive leadership (CISO, CFO, General Counsel, CEO). Format: 30–45 minute meeting + 5–7 slide presentation. Content: Assessment scope & objectives, key findings (CRITICAL & HIGH gaps) + risk ratings, remediation roadmap (timelines, costs, owners), compliance metrics (maturity rating improvement), success criteria. Q&A to address executive concerns (cost, timeline, business impact)[1].

Remediation Tracking (Post-Assessment): Quarterly remediation status reports (Q2, Q3, Q4 2026) tracking completed remediations, in-progress work, blockers, adjusted timeline[1].

APPENDIX A: REFERENCES

[1] NorthStream Technologies Project Materials – Legal Requirements Register, GDPR vs PIPEDA Matrix, Framework Selection & Control Mapping (Projects 1–3)

[2] CIS Benchmarks. Center for Internet Security. <https://www.cisecurity.org/cis-benchmarks>

[3] NIST Cybersecurity Framework 2.0. National Institute of Standards and Technology. <https://www.nist.gov/cyberframework>

Additional References:

- GDPR Official Text. European Commission. <https://gdpr-info.eu/>
 - EDPB Opinion 01/2020 on Data Transfers. European Data Protection Board. <https://edpb.europa.eu/>
 - PIPEDA Summary of Principles. Office of the Privacy Commissioner of Canada. <https://www.priv.gc.ca/>
 - Quebec Law 25 (Loi modifiant la Loi sur la protection des renseignements personnels). National Assembly of Quebec. <https://www.cai.gouv.qc.ca/>
 - AICPA SOC 2 Reports. <https://www.aicpa.org/>
-

APPENDIX B: SAMPLE INTERVIEW QUESTIONS (Minimum 10)

CISO:

1. What is NorthStream's target maturity level for the NIST CSF Govern function by end of 2026?
2. Walk me through your last incident response scenario. How would you detect, assess, and notify regulators?
3. Are you aware of the GDPR Article 33 72-hour DPA notification requirement? How does your incident response plan address this?
4. Is a Privacy Officer appointed? If external, what's the engagement model?
5. What is your top GDPR/PIPEDA/Law 25 compliance risk at NorthStream?

IT Operations Manager:

1. Are the S3 backups encrypted with AWS KMS Customer Master Keys or AWS-managed keys?
2. How often are security patches applied to the 8 web servers? Do you have a patch management policy?
3. Are the 10 Linux web servers compliant with the CIS Ubuntu Linux 22.04 LTS Benchmark? How do you validate compliance?

4. If an employee in the payroll department is terminated, what's the process to revoke access to the HR system?
5. Walk me through your backup procedure for the PostgreSQL database. Is the backup encrypted?

Privacy Officer:

1. Describe the Privacy Officer role at NorthStream. Is it full-time, part-time, or external?
2. Walk me through a scenario: you're notified of unauthorized access to the EU customer database at 2 AM. What's your process?

APPENDIX C: COMPLIANCE TRACKING CHECKLIST

Control ID	Control Name	Current State	Target State	Gap Type	Severity	Owner
GV.OC-01	Privacy Officer Appointment	Not Appointed	Full-Time Role	Control	CRITICAL	CISO
PR.AC-01	Access Control (HR System)	Partial RBAC	Full RBAC + DAM	Implementation	HIGH	IT Ops
PR.DS-01	Data at Rest (S3 Backups)	AWS-Mgd Keys	AWS KMS CMK	Implementation	CRITICAL	Sec Arch
PR.DS-02	Data in Transit	TLS 1.2 Enabled	TLS 1.2+ Enforced	Implementation	MEDIUM	IT Ops
RS.RP-01	Incident Response Plan	Partial (No GDPR/Law 25)	Full (GDPR/Law 25)	Documentation	CRITICAL	CISO
DE.CM-01	Continuous Monitoring	CloudWatch Basic	SIEM Integration	Implementation	HIGH	IT Ops

APPENDIX D: RISK RATING CRITERIA

Severity	Definition	Potential Impact	Examples
CRITICAL	Regulatory violation; major breach risk; violates core security principle	EUR €1M–15M fine; >1000 affected users; system breach	No Privacy Officer; no encryption for sensitive data; no breach notification procedures
HIGH	Non-compliance with important regulatory requirement; significant data loss/breach risk; partial critical control implementation	EUR €100K–1M fine; >100 affected users	Partial encryption; missing audit logging; access control partial RBAC
MEDIUM	Non-compliance with framework best practice; operational issue or minor regulatory gap	EUR €10K–100K fine; <100 affected users	CIS Benchmark compliance 75% vs 85% target; training not 100% complete
LOW	Documentation improvement or procedural refinement; minimal regulatory/business impact	<EUR €10K fine; <10 affected users	Policy formatting; interview documentation needed

REFLECTION: PROJECT TASK 4 INTEGRATION & CHALLENGES

This Compliance Assessment Plan directly builds upon all three prior project deliverables and synthesizes regulatory, framework, and control mapping work into an actionable, 10–12 week assessment roadmap[1][3].

What Was Challenging:

The most challenging aspect was translating abstract regulatory requirements (GDPR Article 32, PIPEDA Principle 4.7, Law 25 Articles 3–8) into **concrete assessment activities** with measurable success criteria and timelines. For example, "GDPR Article 32 requires appropriate encryption" is a legal statement, but defining exactly how to verify compliance (Which systems? What encryption standard? AWS KMS CMK vs AWS-managed? Key rotation policy?) required deep technical understanding combined with legal interpretation. Additionally, balancing **breadth vs. depth** within a 10–12 week window was complex—we could scan 8 web servers or audit 100 configuration items, but had to prioritize based on risk and data classification to ensure assessment is both thorough and achievable within timeline constraints.

Connection to Prior Weeks:

Project Task 3 (Framework Selection & Control Mapping) identified five specific legal-to-technical mappings and assessed implementation challenges, particularly the Privacy Officer gap (Law 25 Articles 3–8). This Plan operationalizes those findings by making Privacy Officer appointment a **CRITICAL** finding in Phase 5 remediation roadmap with explicit timeline (immediate consultant engagement + 3–6 month permanent hire via phased approach from Project Task 3, Part 3). Similarly, Mapping 4 (GDPR Article 33 breach notification) identified that incident response plan **lacks explicit 72-hour DPA notification procedures**—this Plan schedules IRP revision as CRITICAL remediation in Phase 5. Projects 1–2 established PIPEDA Principle 4.7 (Safeguards) and GDPR Article 32 (Encryption) as core compliance obligations; this Plan translates these into concrete technical assessment activities (PR.AC-01/02 access control audits, PR.DS-01/02 encryption validation in Section 3.2). The framework selection (NIST CSF 2.0) chosen in Project Task 3 provides the assessment structure—all six Functions become the organizational lens for findings analysis (Section 3.1)[1][3].